

of Article 33 of the Regulation.

2. The measures taken by the Authority.

Following the notification of the data breach and the subsequent information provided by the Company, the Authority initiated an investigation to assess the circumstances of the incident and the compliance of the Company with the provisions of the Regulation and the Code.

3. Findings of the investigation.

The investigation revealed that the Company had implemented certain security measures; however, these were not sufficient to prevent the attack. The vulnerabilities exploited by the attacker were known and could have been mitigated by timely updates and patches to the systems.

4. Conclusions and recommendations.

In light of the findings, the Authority recommends that the Company enhance its security measures, including regular updates and training for employees on cybersecurity best practices. Additionally, the Company should ensure that all data processing activities are documented and that adequate measures are in place to respond to future incidents.

5. Final provisions.

This decision is communicated to the Company and is subject to appeal in accordance with the applicable legal provisions.

Rome, 4 July 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

Prof. Pasquale Stanzone

President

of Articles 33 and 34 of the Regulation.

It has also been verified that the Company, for the data subject to the data breach for which it acts as the data controller, has communicated the breach to the affected individuals, considering that the risk to their rights and freedoms was high.

2. The initiation of the procedure and the Company's submissions.

On December 15, 2023, the Office notified the Company of the alleged violations of the Regulation found, pursuant to Article 166, paragraph 5, of the Code, with reference to Articles 5, paragraph 1, letter f), 25, 28, paragraph 3, letter f), 32, 33, of the Regulation.

On January 12, 2024, the Company submitted its defense writings and on that occasion highlighted that:

“Postel [...] has established a structured management system aimed at protecting the rights and freedoms of individuals who may be impacted by the processing of Data that it carries out” (see note 01/12/2024 cited, p. 1);

“as for the security profile of the Data, organizational and technical measures are implemented to:

- manage the risks of breaches;
- implement the actions required by current legislation should any breaches nonetheless occur” (see cited note, p. 1);

“in response to the Data breach suffered (the “Breach”), Postel has introduced all necessary actions to:

- comply with the provisions of Articles 33 and 34 of the [...] Regulation [...];
- mitigate as much as possible the impact of the Breach on the rights and freedoms of individuals, as well as other stakeholders involved” (see cited note, p. 2);

“Postel itself is the primary victim of the criminal conduct of Medusa, given the severe economic damages related to the slowdowns of the technological infrastructure that became necessary to mitigate the consequences of the Breach, as well as the need to allocate a significant portion of its human, economic, and technological resources for a considerable period of time to manage the Breach itself” (see cited note, p. 2);

“it has analyzed the events related to the Breach [...] and consequently reports that:

- a series of further organizational and technical measures are underway aimed at strengthening the

security of the processed Data;

- actions are being defined to strengthen its protocols for managing Data breaches in accordance with Articles 33 and 34 of the Regulation, also concerning the management of relationships with any data controllers, pursuant to Article 28, paragraph 3, letter f) of the Regulation” (see cited note, p. 3);

“Postel wishes to express its utmost willingness to cooperate with the Authority, declaring its availability to comply with any additional recommendations that the Authority intends to make” (see cited note, p. 3);

“regarding the alleged insufficiency of the notification of the Breach [...] Postel considers this assessment legally unfounded, as well as not corresponding to the facts, and therefore not shareable. In fact, in fulfilling its obligations under Article 33 of the Regulation, Postel has completed all fields of the standard notification form available on the official website of this esteemed Authority: such completion, while comprehensive, necessarily had a synthetic character” (see cited note, p. 3, 4);

“moreover, the informational element that this esteemed Authority contests as omitted – namely, the type of vulnerability exploited by the attacker – is not expressly mentioned among the mandatory elements of the notification under the Regulation (nor in the recitals cited by this esteemed Authority). Nor are explicit indications on the point found in the Code and/or in measures from the European Data Protection Committee and/or from this esteemed Authority” (see cited note, p. 4);

“the contested omission of the informational element indicated by the Authority is certainly not the result of a lack of transparency on the part of Postel [...] in response to a subsequent specific request on the point from this esteemed Authority, Postel did not hesitate to provide all requested information” (see cited note, p. 4, 5);

“the Authority's assertion that the notification sent by Postel did not indicate ‘[...] the details of the security measures that were applied to the systems involved in the attack [...]’ is not true, as the undersigned diligently completed field F.9 [...] of the standard notification form prepared by the Authority itself” (see cited note, p. 5);

“Postel intends to positively and proactively take note of the observations of this esteemed Authority, committing to carry out awareness-raising activities, exercises, and simulations related to its Data breach management protocols, especially regarding the implementation of a greater level of detail and granularity of the information transmitted to the supervisory authority pursuant to Article 33 of the Regulation. On this occasion, actions will also be implemented to reduce the management times of any Data breaches” (see cited note, p. 5);

“in the case at hand, the management times are largely justified by the complexity and scope of the Breach itself [...]. Furthermore, the Breach occurred during the summer period of partial company closure, resulting in increased difficulty in activating contingency procedures” (see cited note, p. 5); regarding the contestation related to the “failure to adopt measures to mitigate vulnerabilities” “the mentioned vulnerability does not...

constitutes the [underlying cause] of the Violation, to be identified solely and exclusively in the criminal action of Medusa. Consequently, a direct causal link between the existence of the software vulnerability and the occurrence of the Violation cannot be found” (see cited note, p. 6); “the failure to remove the vulnerabilities in question was not due to the absence of corporate procedures and protocols regarding ‘patch and vulnerability management’ or to the inadequacy of the procedures and protocols themselves. In fact, a structured early warning process, detection and issuance of security critical alerts, and scanning and patching of its information systems have been implemented on Postel's infrastructure. This process was also activated concerning the aforementioned vulnerabilities and, in particular, following the early warning, they were temporarily managed by applying workarounds. Unfortunately, however, due to human error in configuring the scanning activities, the Exchange server subject to the attack was excluded from the scanning itself: this accidentally resulted in the failure to patch the aforementioned vulnerabilities, exclusively concerning that system.

Therefore, even regarding the management of the mentioned vulnerabilities, security measures compliant with the requirements of Articles 5, para. 1, lett. f), 25, and 32 of the Regulation were implemented, which, due to an isolated and unfortunate anomaly, were unable to operate effectively” (see cited note, p. 7); “it was deemed appropriate to implement actions to improve the corporate security posture, and a structured action plan is therefore being implemented for this purpose [...] it

includes, among other things, the review and improvement of the management process of security critical alerts. Furthermore, this Cybersecurity Improvement Plan complements a structured and pre-existing system of organizational and technical measures” (see cited note, p. 8); regarding the allegation concerning the “lack of support to the data controllers by the processor” “Postel considers these assessments to be inconsistent with the factual reality [...]. [the statements of some controllers], made in the absence of contradiction, come not from third-party and impartial subjects, but rather from interested parties who would derive solely benefits from attributing to Postel the eventual failure and/or delayed fulfillment of their obligations regarding the protection of personal data (primarily, those under Articles 33 and 34 of the Regulation). Moreover, these statements originate only from three of the twenty-two Postel clients impacted by the Violation” (see cited note, p. 8); “regarding the controller Coop Italia S.p.A., its involvement in the Violation was communicated by Postel shortly after the relevant discovery, first through brief channels and shortly thereafter with communication via PEC. On September 22 [2023], upon completing the necessary analyses, Postel sent Coop Italia the detailed report concerning the Violation, while keeping the communication channels with the client open in the meantime [...]. Furthermore, even after sending the aforementioned report, Postel remained available to the controller regarding further support requests” (see cited note, p. 9); “as for the controller SAT S.p.A., following the first communication sent on August 30 [2023] and the further clarification requests submitted by the same controller the following day, Postel provided the requested feedback after a few days, specifically on September 7 [2023], and in any case after completing the necessary investigative activities” (see cited note, p. 9); “similar considerations can be made regarding what was reported by the controller Nexi S.p.A., to which Postel transmitted the relevant information under Article 28, para. 3, lett. f) of the Regulation on September 8 [2023], that is, just after discovering the involvement of the controller in the Violation, a circumstance that had not emerged previously given that the analyses of the incident perimeter were still underway. Interactions with this client continued in the following days, including the production of a further detailed report on the dynamics of the Violation” (see cited note, p. 9); “the timing of the transmission of the relevant information under Article 28, para. 3, lett. f) of the Regulation by Postel to the three aforementioned clients was in no way due to inertia or lack of collaboration, but rather attributable to the technical times of analysis and information gathering, to be calibrated to the extent of the cyber attack perpetrated by Medusa” (see cited note, p. 9); with reference to Article 83 para. 2 lett. a) of the Regulation “the Violation is connected to the loss of confidentiality and availability of certain Data held by Postel, caused by a cyber attack perpetrated by the professional cybergang Medusa. The individuals involved in the violation are approximately 24,800: however, only concerning 2,161 individuals (approximately 8.71% of the total) was a high level of risk for the rights and freedoms of natural persons identified, necessitating the sending of a communication under Article 34 of the Regulation. As for the Data held by Postel as the data processor, the Violation impacted Data relating to only twenty-two clients, compared to the total documents managed by Postel on behalf of approximately 4,000 clients” (see cited note, pp. 10, 11); with reference to Article 83 para. 2 lett. b) of the Regulation “the Violation was caused by the criminal cyber attack maliciously perpetrated by Medusa [...]”. Consequently, no infringement of the Regulation can be attributed to Postel” (see cited note, p. 11); with reference to Article 83, paragraph 2, letter c) of the Regulation “to mitigate the consequences of the Violation, the corporate procedure for managing cybersecurity events and incidents was immediately activated, including: – opening a ticket for incident management; – convening the technical crisis unit; – conducting ongoing analyses related to the dynamics and scope of the incident; – implementing actions to contain the attack; – sanitizing and subsequently restoring the information systems. Furthermore, Postel has: – implemented communication, collaboration, support, and assistance activities towards the affected parties (in accordance, as recognized by this esteemed Authority, with Article 34 GDPR), clients (especially those for whom Postel operates as data processor), as well as other relevant stakeholders; – filed a complaint with the competent police authorities” (see cited note, p. 11); with reference to Article 83, paragraph 2, letter d) of the Regulation “at the time of the Violation, the following security measures (still in place) were implemented to protect the information systems: – secure authentication procedures; – antivirus systems; – antimalware systems; – systems of the type ‘Defender for Identity’; – intrusion prevention systems; – firewall

systems; – procedures and systems for ‘security information and event management’; – backup procedures; – business continuity and disaster recovery procedures” (see cited note, pp. 11, 12); [OMISSIS] [OMISSIS] “activities for raising awareness, exercises, and simulations regarding data breach management protocols are being implemented, particularly concerning: - the implementation of a greater level of detail and granularity of the information transmitted to the supervisory authority pursuant to Article 33 of the Regulation; - assistance to any data controllers on whose behalf Postel acts as data processor” (see cited note, p. 13); with reference to Article 83, paragraph 2, letter f) of the Regulation “from the moment the Violation was detected, Postel has provided the utmost cooperation to remedy the event itself and mitigate its possible negative effects [...] Furthermore, Postel has proceeded to notify this esteemed Authority pursuant to Article 33 of the Regulation and to respond promptly to its requests for clarification” (see cited note, p. 13); with reference to Article 83, paragraph 2, letter g) of the Regulation “the Violation primarily involved personal and contact data, as well as, in some cases, payment data and data related to identification and/or recognition documents. In an even smaller number of cases, data revealing union membership and health-related data were also impacted” (see cited note, p. 13); with reference to Article 83, paragraph 2, letter h) of the Regulation “[the] Authority became aware of the Violation as a result of the notification [...] made by Postel pursuant to Article 33 of the Regulation immediately after the discovery of the Violation itself and subsequently subject to supplementation” (see cited note, p. 13); with reference to Article 83, paragraph 2, letter i) of the Regulation “no specific corrective measures have been adopted by this esteemed Authority concerning the specific violation contested” (see cited note, p. 14); in relation to Article 83, paragraph 2, letter k) of the Regulation “[the violation resulted in an economic loss to the Company]” (see cited note, p. 14); “the potential imposition of an administrative monetary penalty by this esteemed Authority would further aggravate the economic impact of the Violation on the undersigned, with potential harm also to the stakeholders involved (workers, suppliers, etc.)” (see cited note, p. 15). On January 31, 2024, following a specific request from the Company, a hearing was held for the same. On this occasion, the party represented that: “the Company is certified ISO9001 and ISO27001”; “the corporate policies regarding privacy, also due to the public corporate structure of the group, are based on a structured framework, divided into 14 areas of intervention outlined in specific group privacy guidelines that define roles, procedures, and actions. Moreover, starting from the GDPR, the Company has initiated a continuous improvement action regarding privacy that has also involved staff training and targeted audits”; “the Company believes that the event cannot be attributed to a structural and systemic problem, but to an isolated episode. For this reason, it is emphasized that the Company did not act driven by a logic of advantage in the imperfect application of security measures, as it did not generate any cost savings for the Company itself”; “a recent ruling by the CJEU (case C-340 of 2021) [...] established that the occurrence of a data breach is not proof in re ipsa of a structural inadequacy of the security measures implemented by the data controller”; “with reference to the management of the data breach, it is emphasized that the attack necessitated a manual and detailed inventory of the systems and data involved due to the extent of the violation. The analysis has...

involved all levels of the company and required significant time”;

“to date, the Company is evaluating the implementation of specific training activities dedicated to data breaches to further raise awareness among staff and improve response capacity in similar cases”;

“the Company, starting from the pandemic period and up to the recent war events and weather events affecting the Melzo facility, has been affected by adverse economic conditions. Furthermore, following the cyber attack suffered, the Company chose to block, for security reasons, the production systems and, consequently, some customers turned to other competitors.”

3. Outcome of the proceedings.

3.1 Established facts and observations on the regulations regarding personal data protection.

As a result of the examination of the elements acquired during the investigation and the subsequent assessments of the Authority, based on the findings of the specific technical reports prepared during the proceedings, it emerged that the Company has engaged in conduct that is not compliant with the regulations on personal data protection.

In particular, it has been established that the Company, despite the significance of the data breach

suffered, submitted an incomplete notification of the violations to the Authority; it has also been established that the Company did not maintain conduct in compliance with the data protection regulations even regarding the security measures that it should have adopted in the terms that will be indicated.

In this regard, it is highlighted that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor."

Article 5, paragraph 1, letter f), of the Regulation establishes that personal data must be "processed in a manner that ensures adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical and organizational measures."

In this regard, Article 32 of the Regulation, concerning the security of processing, establishes that "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context and purposes of processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons, the data controller and the data processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk [...]" (paragraph 1) and that "in assessing the appropriate level of security, particular consideration shall be given to the risks presented by the processing, which arise in particular from the destruction, loss, alteration, unauthorized disclosure or accidental or unlawful access to personal data transmitted, stored or otherwise processed" (paragraph 2).

According to Article 25, paragraph 1, of the Regulation, the data controller "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context and purposes of processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons posed by the processing, both at the time of determining the means of processing and at the time of processing itself [must] implement appropriate technical and organizational measures, such as pseudonymization, aimed at effectively applying the principles of data protection, such as minimization, and integrating into the processing the necessary safeguards to meet the requirements of this Regulation and protect the rights of data subjects" (principle of data protection by design).

Article 25, paragraph 2, of the Regulation further provides that the data controller must "implement appropriate technical and organizational measures to ensure that, by default, only personal data necessary for each specific purpose of processing are processed" with reference to "the amount of personal data collected, the scope of processing, the retention period and accessibility," ensuring, in particular, "that, by default, personal data is not made accessible to an indefinite number of natural persons without the intervention of the data subject" (principle of data protection by default).

Article 33 of the Regulation provides that "in the event of a personal data breach, the data controller shall notify the competent supervisory authority pursuant to Article 55 without undue delay and, where feasible, within 72 hours of becoming aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons [...]" (paragraph 1) and "the notification referred to in paragraph 1 shall at least: a) describe the nature of the personal data breach including, where possible, the categories and approximate number of data subjects concerned as well as the categories and approximate number of personal data records concerned; b) communicate the name and contact details of the data protection officer or other contact point where more information can be obtained; c) describe the likely consequences of the personal data breach; d) describe the measures taken or proposed to be taken by

on the part of the data controller to remedy the violation of personal data and also, if applicable, to mitigate its possible negative effects (par. 3).

3.2 Confirmed Violations.

3.2.1 Insufficiency of the information contained in the notification of the violation.

It has been first established, taking into account the findings of the specific technical reports prepared by the Authority, that the Company, following a data breach that affected certain servers and some workstations of the Company, made a notification of the violations, pursuant to art. 33 of the

Regulation, lacking the elements deemed necessary for the exercise, by the Authority, of the tasks and powers provided for by the Regulation.

Art. 33, par. 3, of the Regulation requires that the notification of a data breach, among the elements it must necessarily contain, includes, among other things ("at least"), a description of the nature of the violation (including, where possible, categories and approximate number of data subjects, categories and approximate number of personal data records subject to breach) as well as a description of the measures taken or proposed to be taken to remedy the violation and, if applicable, to mitigate its possible negative effects.

Paragraph 5 of the cited article also provides that, in the event of any data breach, the data controller must document it, keeping track of the "circumstances related to it, its consequences, and the measures taken to remedy it. This documentation allows the supervisory authority to verify compliance with this article."

Recital 87 of the Regulation, referenced by the Guidelines 9/2022 on personal data breach notification under GDPR (adopted on March 28, 2023, see point 26), clarifies in this regard that the notification of a data breach "may lead to an intervention by the supervisory authority within the scope of its tasks and powers provided for by this regulation."

From the literal wording of the cited norms as well as from their systematic reading, it clearly emerges that the notification provided for by art. 33 of the Regulation must contain suitable and exhaustive information regarding the breach event. It is essential, that is, that the notification includes all the necessary information to identify the characteristics of the cyber incident from which the data breach originated. These elements are necessary to allow the Authority, in the event of a data breach, to exercise its powers - and ascertain that appropriate technological and organizational measures have been implemented for the specific case, also with a view to restoring an adequate level of protection for the breached personal data.

Regarding, therefore, the notification submitted by the Company, it is believed instead that it lacks such fundamental elements and, therefore, does not comply with the provisions of art. 33 of the Regulation: in particular, the notification does not indicate the impacted servers (specifically the Exchange servers), the type of vulnerability exploited by the attacker, and some elements regarding the kill chain of the attack. Such information, absent in the initial notification, is not found even in the subsequent integrations, although the activity of integrating the original notification covered a long period of time (from the first communication of 08/17/2023 until the sending of the final version on 10/04/2023), so much so that the aforementioned activity inevitably resulted in an extension of the time for the Authority to verify compliance with data protection regulations.

The mere completion of "all fields of the standard notification form available on the official website of the Authority" (see defense writings of 01/12/2024, p. 4) with generic information (including, for example, "This attack resulted in the blocking of some servers and workstations," see supplementary notification of 10/04/2023, section F.7), cannot be considered sufficient in itself to provide adequate information regarding the breach event, given the vagueness of the content of such information.

This is also taking into account the fact that, in indicating the measures applied to the systems at the time of the event (see section F.9 of the form), the Company made no reference to the patching activities of the indicated vulnerabilities, or to the mitigation/elimination actions of the vulnerabilities carried out, but limited itself to listing the measures generically adopted ("The servers and endpoints were and are protected through authentication systems, antivirus, antimalware, defender for identity, IPS, firewall, and SIEM. Backup and business continuity and disaster recovery systems are in place"; see supplementary notification of 10/04/2023, section F.9).

The information regarding the type of vulnerabilities used by the attacker and the details of the security measures that were applied to the systems involved in the attack were indeed provided only in response to a specific request for information from the Authority (in particular, request for information of 10/13/2023).

The cited Guidelines 9/2022 on personal data breach notification under GDPR clarify in this regard that, in any case, in addition to the information expressly required by the Regulation, the data controller, evaluated the specific case, must proactively provide all those additional necessary information to fully explain the circumstances of each case of data breach (see point 54 "Article 33(3)

GDPR states that the controller «shall at least» provide this information).

data siano idonee a garantire un livello di sicurezza adeguato al rischio, tenendo conto della natura, dell'ambito, del contesto e delle finalità del trattamento, nonché del rischio di violazione dei dati personali”.

3.2.3 Mancata registrazione delle violazioni

È emerso che la Società non ha registrato le violazioni di dati personali, come previsto dall'art. 33, par. 5 del Regolamento. Tale registrazione è fondamentale per garantire che il titolare del trattamento possa dimostrare la conformità agli obblighi di notifica e per consentire un'analisi adeguata delle violazioni stesse. La mancata registrazione delle violazioni compromette la capacità della Società di gestire in modo efficace le violazioni future e di attuare misure correttive.

3.2.4 Mancata comunicazione delle violazioni all'Autorità

In aggiunta, è stato accertato che la Società non ha comunicato all'Autorità competente le violazioni di dati personali entro il termine di 72 ore, come richiesto dall'art. 33, par. 1 del Regolamento. La tempestività nella comunicazione delle violazioni è cruciale per consentire all'Autorità di valutare il rischio per i diritti e le libertà delle persone fisiche e di adottare le misure necessarie per proteggere i soggetti interessati.

4. Conclusioni

In considerazione di quanto sopra esposto, si conclude che la Società ha violato diverse disposizioni del Regolamento, in particolare gli articoli 5, 25, 32 e 33. La condotta della Società, caratterizzata dalla mancata adozione di misure di sicurezza adeguate, dalla registrazione inadeguata delle violazioni e dalla mancata comunicazione tempestiva all'Autorità, ha esposto i dati personali a un rischio significativo e ha compromesso la protezione dei diritti e delle libertà degli interessati. Pertanto, si raccomanda l'adozione immediata di misure correttive e preventive per garantire la conformità al Regolamento e per proteggere i dati personali trattati dalla Società.

treatment is adequate to such risks, taking into account the state of the art, the costs of implementation as well as the nature, scope, context, and purposes of such treatment” (point 42). Furthermore, in the aforementioned ruling, the Court of Justice clarified that “from the provisions of Article 5, paragraph 2, Article 24, paragraph 1, and Article 32, paragraph 1, of the GDPR, it is unambiguously clear that the burden of proving that personal data is processed in such a way as to ensure adequate security in accordance with Article 5, paragraph 1, letter f), and Article 32 of that regulation lies with the data controller in question” (point 52), and further on the matter, “on the one hand, since the level of protection under the GDPR depends on the security measures adopted by data controllers, they must be compelled, bearing the burden of demonstrating the adequacy of such measures, to do everything possible to prevent processing operations that do not comply with that regulation” (point 55).

From the examination of what has been stated and the documentation produced by the Company, it has become evident that it did not do everything it could to prevent the data breach, considering that, as already extensively clarified, the Company did not adopt those mitigation measures that, publicly disseminated, were strongly recommended first by Microsoft and, at the national level, also by the National Cybersecurity Agency.

In this regard, it is noted that what was presented by the Company cannot be deemed adequate to justify the lack of complete and timely updates of its systems. The Company's assertion that “due to human error in the configuration of the scanning activities, the Exchange server subject to the attack was excluded from the scanning itself” (see defense writings of 01/12/2024, p. 7) is of no merit: given the criticality of the vulnerabilities in question (assessed, as already noted, by Microsoft as high risk for the loss of integrity, availability, and confidentiality of the related data, see <https://msrc.microsoft.com/update-guide/en-US/advisory/CVE-2022-41040>, and <https://msrc.microsoft.com/update-guide/en-US/advisory/CVE-2022-41082>) and the sensitivity of the impacted systems, the patching and updating activities should have been subjected to repeated and necessarily redundant checks by the Company and not carried out based on a manual activity that was not subject to any subsequent verification.

Regarding its own systems, the Company, for a very long period of time (almost 12 months), was unable to guarantee the necessary protection against the loss and dissemination of the personal data processed, except partially through workarounds, which by their nature should be considered a temporary and emergency solution, among other things and in any case not applied to all Exchange servers.

In this regard, it is noted that the failure to update all systems, although not directly the cause of the attack perpetrated by the Medusa cyber gang, certainly rendered the systems and the data processed by them vulnerable, making them inadequately protected against the impending risks.

For these reasons, the Company was therefore unable to ensure on a permanent basis the confidentiality, integrity, and resilience of the processing systems and services and did not adopt a procedure aimed at regularly verifying the effectiveness of the technical measures applied to them.

In relation to the overall motivations reported above, it is therefore believed that the Company has violated Articles 5, paragraph 1, letter f), 25, and 32 of the Regulation.

As for the contestation made at the beginning of the proceedings regarding the violation of Article 28, paragraph 3, letter f), of the Regulation concerning the alleged shortcomings in the assistance provided to the data controllers involved in the data breach event, it is believed that what was represented by the Company in the defense writings of January 12, 2024, has highlighted how it has implemented adequate and timely assistance activities towards the data controllers involved in the event; this taking into account the necessary actions for the analysis of the cyber incident that the Company had to carry out.

For these reasons, it is not believed that there are grounds in this case to adopt measures concerning the violation of Article 28, paragraph 3, letter f), of the Regulation, contained in the notification of violations dated December 15, 2023, which is therefore deemed to be archived in the part concerning this specific contested profile.

4. Conclusions: declaration of unlawfulness of the treatment. Corrective measures pursuant to Article 58, paragraph 2, Regulation.

For the reasons stated above, the Authority believes that the statements, documentation, and reconstructions provided by the data controller during the investigation do not allow for overcoming the observations notified by the Office with the initiation of the proceedings and are therefore inadequate to allow for the archiving of this proceeding, nor do any of the cases provided for by Article 11 of the Garante Regulation No. 1/2019 apply.

The conduct carried out by the Company - specifically, the submission to the Authority of a data breach notification lacking the fundamental elements and the failure to adopt updating activities for its systems - is indeed unlawful, in the terms outlined above, in relation to Articles 5, paragraph 1, letter f), 25, 32, and 33 of the Regulation.

The violation, established in the terms outlined in the reasoning, cannot be considered "minor," taking into account the nature and severity of the violation itself and the degree of responsibility (see Recital 148 of the Regulation). The Authority also took into account the average level of severity of the violation in light of all relevant factors in the specific case, and in particular the nature, severity, and duration of the violation, considering the nature, purpose, or objective of the processing in question as well as the number of affected individuals harmed by the damage and the level of damage they suffered. The Authority also considered the criteria related to the intentional or negligent nature of the violation and the categories of personal data affected by the violation (see Art. 83, para. 2 and Recital 148 of the Regulation).

Therefore, in light of the corrective powers conferred by Art. 58, para. 2 of the Regulation, in light of the specific case:

a. the controller is ordered:

- to carry out a timely assessment of vulnerabilities in its systems and to promptly resolve them, taking into account the level of risk arising from the inadequate protection of the personal data processed;

- to establish a formalized procedure for managing vulnerabilities, which includes, in particular, the planning of controls for all IT assets of the organization in order to detect any presence of known or potential vulnerabilities as well as the identification of the related correction and mitigation procedures;
- to identify, for the various IT assets through which the company processes personal data, the values related to the mean time to detect vulnerabilities (MTTD) and the mean time to respond (MTTR), which are adequate considering the risk to the rights and freedoms of individuals.

b. the application of an administrative monetary sanction is ordered pursuant to Art. 83 of the Regulation, proportionate to the circumstances of the specific case (Art. 58, para. 2, lett. i) of the Regulation).

5. Adoption of the injunction order for the application of the administrative monetary sanction and accessory sanctions (Arts. 58, para. 2, lett. i), and 83 of the Regulation; Art. 166, para. 7, of the Code).

As a result of the proceedings, it is found that Postel S.p.A. has violated Arts. 5, para. 1, lett. f), 25, 32, and 33 of the Regulation. For the violation of the aforementioned provisions, the application of the administrative monetary sanction provided for by Art. 83, para. 4, lett. a), and 5, lett. a) of the Regulation is foreseen, through the adoption of an injunction order (Art. 18, Law 24.11.1981, No. 689).

It is deemed necessary to apply paragraph 3 of Art. 83 of the Regulation where it states that “If, in relation to the same processing or related processing, a controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative monetary sanction shall not exceed the amount specified for the most serious violation,” the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Art. 83, para. 5.

With reference to the elements listed in Art. 83, para. 2 of the Regulation for the purpose of applying the administrative monetary sanction and its quantification, considering that the sanction must “in any case [be] effective, proportionate, and dissuasive” (Art. 83, para. 1 of the Regulation), it is represented that, in this case, the following circumstances have been considered:

in relation to the nature of the violation, it involved, among other things, cases punished more severely under Art. 83, para. 5, of the Regulation (general principles of processing, in particular the principle of integrity and confidentiality);

in relation to the severity of the violation, the circumstance of the significant number of individuals whose personal data were involved in the violation (about 25,000), the loss of availability of a portion of the data subject to the violation, and the high impact that the violation may have caused to the affected individuals (in terms of loss of control over data, identity theft, fraud, reputational risks) was taken into account;

with regard to the duration of the violation, the duration of the violation was considered relevant since, from the time the vulnerabilities exploited for the attack were made known (September 2022), the Company, almost twelve months later (August 2023), had not yet updated its systems;

the degree of responsibility of the controller or processor, taking into account the technical and organizational measures implemented pursuant to Arts. 25 and 32 of the Regulation, which were specifically highlighted in the proceedings;

with reference to the intentional or negligent nature of the violation and the degree of responsibility of the controller, the conduct of the Company was considered, which failed to adopt appropriate technical measures to protect the personal data processed on its systems, despite public warnings about vulnerabilities and countermeasures to be adopted, coming from the software provider and the ACN;

in favor of the Company, account was taken of the cooperation with the supervisory Authority demonstrated during the proceedings and the decision to update the systems and implement a Cybersecurity Improvement Plan in order to update and improve the management process of security critical alerts.

It is also believed that it is relevant, in the case of...

**In the case at hand, taking into account the aforementioned principles of effectiveness, proportionality, and deterrence to which the Authority must adhere in determining the amount of the sanction (Article 83, paragraph 1, of the Regulation), first and foremost the economic conditions of the

offender, determined based on the revenues achieved by the Company with reference to the ordinary financial statements for the year 2023. Lastly, consideration is given to the amount of sanctions imposed in similar cases.**

In quantifying the sanction, it has also been taken into account that, in this case, the monetary sanction is in addition to other corrective measures imposed by the provision.

In light of the above-mentioned elements and the evaluations made, it is deemed appropriate, in this specific case, to apply to Postel S.p.A. the administrative sanction of payment of an amount equal to €900,000 (nine hundred thousand euros).

In this context, it is also considered, given the nature of the violations identified that concerned the general principles of processing as well as security measures and the content of the data breach notification, that pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Guarantor's Regulation No. 1/2019, the publication of this provision on the Guarantor's website should proceed.

It is also deemed that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

****ALL OF THE ABOVE CONSIDERED, THE GUARANTOR****

notes the illegality of the processing carried out by Postel S.p.A., represented by the legal representative pro tempore, with registered office at Viale Europa, 175, Rome, Tax Code 04839740489, pursuant to Article 143 of the Code, for the violation of Articles 5, paragraph 1, letter f), 25, 32, and 33 of the Regulation;

****DETERMINES****

to archive the contestation adopted against Postel S.p.A. represented by the legal representative pro tempore, with act of December 15, 2023, limited to the violation of Article 28, paragraph 3, letter f), of the Regulation;

****ORDERS****

****Postel S.p.A.:****

****a. pursuant to Article 58, paragraph 2, letter d) of the Regulation:****

- **to conduct a vulnerability assessment of its systems and to promptly resolve them, taking into account the level of risk arising from the inadequate protection of personal data processed, within 90 days from the notification of this provision;**
- **to establish a formalized procedure for managing vulnerabilities, which includes, in particular, the planning of the control of all IT assets of the organization to detect any presence of known or potential vulnerabilities as well as the identification of the relevant correction and mitigation procedures, within 90 days from the notification of this provision;**
- **to identify, for the various IT assets through which the company processes personal data, values related to the mean time to detect vulnerabilities (MTTD) and the mean time to respond (MTTR), that are adequate considering the risk to the rights and freedoms of individuals, within 90 days from the notification of this provision.**

****b. to pay the aforementioned sum of €900,000 (nine hundred thousand), according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/1981. It is reminded that the offender retains the option to settle the dispute by paying – always according to the methods indicated in the attachment – an amount equal to half of the imposed sanction, within the term provided for the submission of the appeal as indicated below (Article 166, paragraph 8, of the Code);****

****ORDERS****

****pursuant to Article 58, paragraph 2, letter i) of the Regulation to Postel S.p.A., to pay the sum of €900,000 (nine hundred thousand) as an administrative monetary sanction for the violations indicated in this provision;****

****DISPOSES****

****the publication of this provision on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Guarantor's Regulation No. 1/2019, and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.****

****Requests Postel S.p.A. to communicate what initiatives have been undertaken to implement the provisions of this provision and to provide adequately documented feedback pursuant to Article 157 of the Code, within 120 days from the date of notification of this provision; any failure to respond may result in the application of the administrative sanction provided for in Article 83, paragraph 5, letter e) of the Regulation.****

****Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree No. 150/2011, an appeal against this provision may be submitted to the ordinary judicial authority, with an application filed at the ordinary court of the place identified in the same Article 10, within thirty days from the date of communication of the provision itself, or sixty days if the appellant resides abroad.****

****Rome, July 4, 2024****

****THE PRESIDENT****

****Stanzione****

****THE REPORTER****

****Stanzione****

****THE SECRETARY GENERAL****

****Mattei****